MODULE 29 · DOMAIN 5 - NETWORKING AND CONTENT DELIVERY

Security Groups, NACLs and Troubleshooting

Stateful versus stateless, ephemeral ports, flow logs, Reachability Analyzer - and a ladder that works every time.

DOMAIN 5 of 5 EXAM WEIGHT 18% MODULE 29 of 35

admin@sthithapragna.com

Security groups are **stateful**; network ACLs are **stateless**. Almost every confusing connectivity failure comes down to **return traffic**.

Security group or network ACL?

SECURITY GROUP

Stateful, at the instance

- Attached to an elastic network interface
- Allow rules only; there is no deny
- Return traffic automatically permitted
- All rules evaluated together

NETWORK ACL

Stateless, at the subnet

- Attached to a subnet, so it covers everything in it
- Allow and deny rules, evaluated by rule number
- Return traffic needs its own rule
- First matching rule wins, then evaluation stops

THE TIEBREAKER

A security group cannot block a specific IP address, because it has no deny. Blocking one bad address is a NACL job, or AWS WAF.

Security groups in detail

- A **new** security group allows **no inbound and all outbound**. The **default** security group also allows inbound from itself.
- Rules can reference an **IP range, a prefix list, or another security group**.
- Multiple security groups on one interface are **additive**. The union of their allow rules applies; nothing subtracts.
- Default limits: **60 inbound and 60 outbound rules** per group per IP version, and **5 groups per interface**, adjustable to 16.

> ON THE EXAM
>
> Groups are additive, so adding one can only widen access. If you need to narrow it, you must edit or remove a rule, not add a group.

Referencing a security group

- Instead of an address range, a rule can name **another security group** as its source. Anything in that group is allowed.
- The rule stays correct as instances are added and removed, because it describes a **role** rather than an address.
- The classic pattern: the database group allows port 3306 **from the application group**, never from a CIDR range.
- References work **within a VPC and across peered VPCs in the same Region**. They do not work across Regions.

> ON THE EXAM
>
> This is the single best practice in VPC security. An address range goes stale; a security group reference describes intent and never does.

Network ACLs in detail

- Rules are **numbered** and evaluated from lowest to highest. The **first match wins** and evaluation stops there.
- So a deny at rule 100 beats an allow at rule 200, even though the allow exists. Rule order is the logic.
- The **default** NACL allows all inbound and outbound. A **custom** NACL **denies everything** until you add rules.
- Number rules in gaps of 100, so you can insert one later without renumbering everything.

> ON THE EXAM
>
> Creating a custom NACL and attaching it before adding rules cuts off the subnet completely. Default allows all; custom denies all.

Ephemeral ports: the classic trap

- A response does not come back on the port you sent to. The client picks a high **ephemeral** source port, and the response goes there.
- So a NACL allowing inbound 443 must also allow **outbound 1024 to 65535** for the response to leave.
- Ranges vary: **Linux 32768-60999**, **Windows 49152-65535**, and **NAT gateways and load balancers use 1024-65535**.
- Security groups are unaffected, because they are stateful and track the connection.

> ON THE EXAM
>
> "It connects and then hangs" or "works one way only" is a NACL missing the ephemeral port range. Nothing else produces that exact symptom.

Where a packet is checked

01

Leaves the source

Source security group outbound rules.

02

Leaves the subnet

Source subnet's NACL outbound rules.

03

Routing

Route table decides the next hop.

04

Enters the subnet

Destination subnet's NACL inbound rules.

05

Reaches the target

Destination security group inbound rules.

ON THE EXAM

Then the response makes the same journey in reverse. Security groups remember it; NACLs do not, which is why the return trip needs its own rules.

The connectivity ladder

- **1. Routing.** Is there a route to the destination, and a route back? Both directions need one.
- **2. Security groups.** Outbound on the source, inbound on the destination. Check both, not just the destination.
- **3. NACLs.** Both subnets, both directions, and **ephemeral ports on the return path**.
- **4. The thing itself.** Is the process listening, on that port, on the right interface? DNS resolving to the right address?

> ON THE EXAM
>
> Work down in order and stop at the first failure. Most people start at step 2, find nothing, and never check that a route exists in both directions.

VPC Flow Logs

- Records accepted and rejected traffic at the **VPC, subnet or network interface** level. Destinations: CloudWatch Logs, S3, or Amazon Data Firehose.
- Each record shows source, destination, ports, protocol, packets, bytes and an **action of ACCEPT or REJECT**.
- A **custom format** adds fields such as **pkt-srcaddr** and **pkt-dstaddr**, which matter behind a NAT gateway or Transit Gateway.
- Aggregation interval is **1 or 10 minutes**, so flow logs are never a real-time view.

> ON THE EXAM
>
> REJECT tells you a security group or NACL blocked it. Silence tells you the packet never arrived, which is a routing or DNS problem.

What flow logs do not capture

- Traffic to and from the **instance metadata service** at 169.254.169.254, and the **Amazon Time Sync** service.
- **DHCP traffic**, and traffic to the **reserved VPC router address**.
- Traffic to the **Amazon-provided DNS server**. Queries to your own DNS servers **are** captured.
- **Windows licence activation** traffic to the AWS-managed activation servers.

> ON THE EXAM
>
> "We have flow logs and see nothing for the metadata service" is expected behaviour, not a fault. For DNS visibility, use Route 53 Resolver query logging.

Reachability Analyzer

- Analyses your **configuration** between two endpoints and reports whether a path exists. It **sends no packets**.
- When a path is blocked it names the **specific component**: this security group, this NACL rule, this missing route.
- It works **before anything is deployed** and on resources that are stopped, because it reads configuration rather than observing traffic.
- Charged **per analysis**, at a small fixed price. It is in the exam's in-scope service list.

> ON THE EXAM
>
> It evaluates the whole path across route tables, security groups, NACLs, gateways, peering and Transit Gateways. That is what makes it faster than reading them yourself.

Flow logs or Reachability Analyzer?

REACHABILITY ANALYZER

Could traffic flow?

- Static configuration analysis
- Names the blocking component precisely
- Works on stopped or undeployed resources
- Start here when something never connects

FLOW LOGS

What traffic did flow?

- Observed records of real packets
- ACCEPT and REJECT for actual attempts
- Shows intermittent and volumetric problems
- Start here when it works sometimes

THE TIEBREAKER

Never connects means configuration, so use the analyzer. Sometimes fails means behaviour, so use flow logs. That split saves a lot of time.

Network Access Analyzer

- Reachability Analyzer answers about **one specific path**. Network Access Analyzer finds **all paths matching a description**.
- You define a **Network Access Scope**: for example, any path from the internet to any resource in a subnet holding regulated data.
- It then reports every route that satisfies it, including ones nobody knew existed through peering or a Transit Gateway.
- It is **configuration analysis**, so it finds paths that are possible, not paths anybody has used.

> ON THE EXAM
>
> "Prove nothing on the internet can reach these subnets" is Network Access Analyzer. A single-path check cannot prove a negative across an estate.

Security group references across a Transit Gateway

- By default, a Transit Gateway **discards security group information** about forwarded traffic.
- So a rule allowing traffic **from another security group** silently fails for anything arriving through the Transit Gateway.
- **Security group referencing support** must be enabled on the Transit Gateway VPC attachment, within a Region.
- Reachability Analyzer reports this specifically, with explanation codes for references not preserved and referencing support.

> ON THE EXAM
>
> This is why a rule that works within a VPC fails across a Transit Gateway. The rule is correct; the group identity did not survive the journey.

Watching the network itself

- Skill 5.3.5 names **CloudWatch network monitoring**, which is three things.
- **Network Flow Monitor**: agent-based, near real-time packet loss and latency between your instances and toward AWS services.
- **Internet Monitor**: the health of the internet paths your users take to reach you, by city and network provider.
- **Network Synthetic Monitor**: probes between chosen endpoints, so you measure a path continuously rather than during an incident.

> ON THE EXAM
>
> Flow logs tell you a connection was rejected. Network Flow Monitor tells you it was accepted and slow, which is a different and harder problem.

Traffic Mirroring

- Copies **actual packets** from an elastic network interface to a monitoring appliance or a Network Load Balancer.
- Flow logs are metadata. Mirroring gives you the **payload**, which is what intrusion detection and packet analysis need.
- **Filters** select which traffic is mirrored, so you copy the flows that matter rather than everything.
- It consumes instance bandwidth and generates a lot of data. It is a targeted tool, not a default.

> ON THE EXAM
>
> "We need to inspect packet contents" is mirroring. Flow logs can never answer that, because they record that a flow happened, not what was in it.

> An engineer creates a custom network ACL for a subnet and adds an inbound rule allowing TCP 443 from 0.0.0.0/0. Instances in the subnet can be reached on 443, but every response times out and connections hang.
>
> The security groups allow all outbound traffic.

What is missing?

A An outbound NACL rule allowing the ephemeral port range, because NACLs are stateless

B An inbound security group rule for port 443

C An outbound NACL rule allowing TCP 443

D A route to the internet gateway

◆ PAUSE AND DECIDE

What is missing?

A Outbound ephemeral range

The response leaves from port 443 to the client's high ephemeral port. A stateless NACL needs an outbound rule covering that range.

B Inbound SG rule for 443

Traffic is arriving, which proves the security group already permits it. And the symptom is the response, not the request.

C Outbound NACL rule for 443

The near miss, and it names the wrong port. The response leaves from 443 but is destined for the ephemeral port, which is what the rule must match.

D Route to the IGW

The request arrived, so routing inbound works. A missing route would prevent the connection entirely rather than hanging it.

THE SIGNAL

Connects then hangs is the stateless signature. Option C is the trap for anyone who knows the rule is needed but matches on the wrong port.

> An application in VPC A cannot reach a database in VPC B through a Transit Gateway. The database's security group allows the database port from the application's security group, and that same rule works correctly for application instances inside VPC B.
>
> Route tables and NACLs have been verified as correct.

What is the most likely cause?

A. The Transit Gateway discards security group information unless referencing support is enabled on the attachment

B. Security group references never work across VPCs

C. The database security group needs the application's CIDR range instead

D. The Transit Gateway needs a NAT gateway on the path

◆ PAUSE AND DECIDE

What is the most likely cause?

A Referencing support not enabled

By default a Transit Gateway discards security group information about forwarded traffic, so a group-referencing rule cannot match.

B References never work across VPCs

Too absolute. They work across peered VPCs in the same Region, and across a Transit Gateway once referencing support is enabled.

C Use a CIDR range

A workaround that would work, at the cost of the maintainable rule. The question asks for the cause, not a way around it.

D NAT gateway on the path

NAT is for internet access. Both VPCs are private and routing has already been verified.

THE SIGNAL

The controlled comparison is the clue: the identical rule works inside VPC B and fails across the Transit Gateway. Only the path differs.

> A team must prove to an auditor that no resource in three regulated subnets can be reached from the internet by any path. That includes peering connections and a Transit Gateway other teams manage.
>
> They have VPC Flow Logs enabled on all VPCs.

What should the team use?

A. Network Access Analyzer with a scope matching any path from the internet to those subnets

B. Reachability Analyzer between the internet gateway and each instance

C. Analyse the flow logs for accepted inbound traffic from public addresses

D. A Config rule checking security groups for 0.0.0.0/0 rules

◆ PAUSE AND DECIDE

What should the team use?

A Network Access Analyzer scope

Finds every path matching a description across the whole estate, including routes through peering and Transit Gateways nobody documented.

B Reachability Analyzer per instance

Tests one specified path at a time. Proving no path exists means enumerating every possible source, which is what a scope does for you.

C Flow log analysis

Shows traffic that happened. A path nobody has used yet produces no records, and absence of traffic is not absence of a path.

D Config rule on security groups

Checks one component. A path can be blocked or open for reasons in route tables, NACLs or gateways that a security group rule never reveals.

THE SIGNAL

Proving a negative is the giveaway. A single-path tool cannot do it; only a scope that enumerates all matching paths can.

> Instances in a private subnet intermittently fail to resolve DNS names. VPC Flow Logs for the subnet show no records at all relating to DNS traffic. The team takes that as evidence that queries are blocked before they leave the instance.
>
> The instances use the Amazon-provided DNS server.

What should the team understand and do?

A Flow logs do not capture traffic to the Amazon-provided DNS server. Use Route 53 Resolver query logging instead

B The flow log needs a custom format including pkt-srcaddr

C The NACL is blocking UDP 53 outbound

D enableDnsSupport must be disabled and re-enabled on the VPC

◆ PAUSE AND DECIDE

What should the team understand and do?

A Flow logs never capture it; use Resolver query logging

Documented behaviour. The absence of records is expected and proves nothing, and Resolver query logging is the tool that does show these queries.

B Custom format with pkt-srcaddr

Adds fields to records that exist. It cannot create records for traffic flow logs never capture.

C NACL blocking UDP 53

Would block resolution consistently rather than intermittently, and it is the conclusion the team drew from evidence that does not support it.

D Toggle enableDnsSupport

If DNS support were disabled, resolution would fail completely and permanently, not intermittently.

THE SIGNAL

The team's inference is the error being tested. Silence in flow logs about Amazon DNS is expected, so it is evidence of nothing at all.

> A new application server cannot connect to a database. It has never worked. The environment spans two VPCs joined by peering. There are several security groups, custom NACLs and multiple route tables, maintained by different teams.
>
> An engineer has spent two hours reading configuration without finding the cause.

What is the most efficient next step?

A. Run Reachability Analyzer between the application instance and the database, and read the blocking component it names

B. Enable VPC Flow Logs and look for REJECT records

C. Temporarily open all security groups to 0.0.0.0/0 to isolate the layer

D. Enable Traffic Mirroring on the application instance

◆ PAUSE AND DECIDE

What is the most efficient next step?

A Reachability Analyzer

Has never worked means configuration. The analyzer evaluates the whole path across both VPCs and names the component, in seconds.

B Flow logs for REJECT

Useful, and it only shows the first blocking point that generates a record. A missing route produces no REJECT at all.

C Open everything temporarily

The genuinely dangerous answer. It creates a real exposure, and if the cause is routing it changes nothing while you believe you have tested it.

D Traffic Mirroring

Captures packet contents on a path that is not passing packets. There is nothing to mirror.

THE SIGNAL

"It has never worked" is the phrase. Configuration problems belong to the analyzer; flow logs are for things that used to work or work sometimes.

The five things to carry forward

- **Stateful versus stateless.** Connects then hangs means a NACL missing the ephemeral range on the return path.
- **Reference security groups, not CIDR ranges.** The rule then describes a role and never goes stale.
- **A Transit Gateway discards group references** unless referencing support is enabled on the attachment.
- **Never worked means Reachability Analyzer. Works sometimes means flow logs.**
- **Flow logs never capture Amazon DNS traffic.** Silence there is expected, not evidence.

> ON THE EXAM
>
> Next: private and hybrid connectivity - endpoints, PrivateLink, peering, Transit Gateway and VPN.